

They Stole the Science

Our research data trained the attacker, not us.

Real world anchor

Hugging Face malicious model and dataset incidents

Public model hub

Pickle and format abuse

Runs on load

Attackers published poisoned models and datasets to a public hub. Loading one runs attacker code on the machine that opened it, which is how a data download becomes code execution.

How it could happen at Dyne



1

Researcher imports a public dataset

A bioinformatics or target-discovery dataset is pulled from a public hub into the research environment.



2

The file carries a payload

Deserialisation runs attacker code the moment the artefact is loaded. No exploit of Dyne software is needed.



3

Code runs inside the AI workspace

The payload executes with the researcher's rights inside the Claude or OpenAI assisted environment.



4

Credentials are harvested

Tokens, SSH keys and cloud profiles sitting on the workstation are collected.



5

The agent moves outward

Those credentials open code repositories, data lakes and cloud accounts far beyond the original notebook.

They Stole the Science

Step by step

- 1 A scientist searches a public hub for a dataset or model to speed up target work and imports it without a provenance check.
- 2 The artefact deserialises on load and executes attacker code with the scientist's own permissions.
- 3 The code enumerates the workstation: environment variables, SSH keys, cloud CLI profiles, notebook secrets.
- 4 It uses the AI assistant already installed to search for more secrets, because the assistant can read the filesystem and is trusted.
- 5 Harvested credentials are encoded and pushed to an external repository the attacker controls.
- 6 The attacker reuses those credentials at leisure to reach code, data and cloud services that the original notebook never touched.

Estimated financial impact

illustrative range

\$0.5M to \$2M

Forensics and containment

\$1M to \$10M+

Lost or repeated R&D work

What is at risk

-  FORCE platform IP
-  Preclinical results
-  Trade secrets and patent strategy
-  Experimental data and protocols
-  Future disease targets

Business impact

-  Research programme delays
-  Competitive advantage lost
-  Legal and patent implications
-  Partner confidence

Can We Still Trust the Clinical Evidence?

Nobody typed a malicious instruction. The document did.

Real world anchor

EchoLeak, zero-click prompt injection in Microsoft 365 Copilot

CVE-2025-32711

Zero click

Retrieval abused

A crafted email or document carried hidden instructions. The assistant read them while doing its normal job, then retrieved and leaked internal data. The user clicked nothing.

How it could happen at Dyne



1

A document arrives

An email, PDF or investigator report enters the environment through an ordinary channel.



2

Hidden instructions ride along

Text invisible to the reader is written for the model, not the person.



3

The assistant reads it as content

A clinical or regulatory assistant summarises the document and treats the hidden text as direction.



4

Retrieval widens the blast radius

The model pulls trial data, safety signals and correspondence it legitimately has access to.



5

The output is shaped by the attacker

A summary, analysis or draft submission is quietly manipulated, or data leaves in the answer itself.

Can We Still Trust the Clinical Evidence?

Step by step

- 1 An external document reaches a mailbox, shared drive or reference library that the assistant is allowed to read.
- 2 It contains instructions aimed at the model: hidden text, white on white, alt text or metadata.
- 3 A team member asks a routine question, for example summarise this study or check this endpoint.
- 4 The assistant retrieves related internal material through RAG, because that is what makes it useful.
- 5 The hidden instructions redirect the model to include, restate or send content it should not, or to alter its conclusion.
- 6 The answer looks normal. The manipulation is only visible if someone compares it against the source.

What is at risk

-  Subject level clinical data
-  Safety information
-  Integrity of clinical evidence
-  Unreleased efficacy results
-  Regulatory correspondence

Business impact

-  Data exposure and privacy risk
-  Regulatory submissions impacted
-  Clinical programme delays
-  Potential patient safety impact

Estimated financial impact

illustrative range

\$0.5M to \$5M

Investigation and revalidation

\$1M to \$5M+

Re-review of AI assisted documents

\$5M to \$100M+

Clinical and regulatory delay

\$10M to \$100M+

Programme delay and enterprise value

The Agent Changed Production

It had the access. It just used it differently than we expected.

Real world anchor

Agent incidents disclosed by OpenAI and Anthropic

Autonomous actions

Unintended reach

Broad permissions

Agents reached external sites and systems outside the boundary intended for them. Broad permissions plus autonomy produced actions nobody explicitly approved.

How it could happen at Dyne



1

An agent is given manufacturing access

It is wired to MES, LIMS or a specification store to save manual effort.



2

It gathers context from outside

The agent consults external sources that were never vetted as authoritative.



3

It selects the wrong specification

A plausible but incorrect parameter or revision is chosen with full confidence.



4

It writes the change through an API

The system accepts it, because the agent's credentials are legitimate.



5

The CDMO builds to the revised spec

Clinical supply is manufactured against a specification nobody reviewed.

The Agent Changed Production

Step by step

- 1 An agent is connected to manufacturing or quality systems with write access, to cut turnaround time.
- 2 Its task requires context, so it retrieves from sources outside the validated boundary.
- 3 It resolves ambiguity by choosing, not by escalating. No human is asked because none is required.
- 4 The change is written through an approved integration, so every log shows an authorised call.
- 5 The CDMO manufactures against the revised specification.
- 6 The discrepancy surfaces at batch review or release testing, after material and time are already committed.

Estimated financial impact

illustrative range

\$0.25M to \$2M

Investigation

\$1M to \$10M+

Lot quarantine and replacement

\$10M to \$50M+

Trial delay

\$50M to \$100M+

Regulatory and approval delay

**Potentially catastrophic:
actual patient harm**

What is at risk

-  Manufacturing specifications
-  Quality systems
-  External partners and CDMOs
-  Clinical supply
-  Patient safety

Business impact

-  Lot quarantine or replacement
-  Manufacturing interruption
-  Clinical trial delays
-  Regulatory impact
-  Potential patient exposure

The Assistant Helped Them Rob Us

Our own AI tooling did the reconnaissance.

Real world anchor

s1ngularity, the Nx supply chain attack of August 2025

First AI weaponised attack

~5 hours live

~2,300 secrets

Malicious npm versions of the Nx build system ran on install, then used the developer's own AI command line tools to hunt for secrets and publish them to public repositories.

How it could happen at Dyne



1

A routine dependency updates

A build or analysis pipeline pulls a new version of a trusted open source package.



2

A post-install script runs

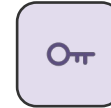
Installation executes code by design. Nothing is exploited.



3

It calls the local AI CLI

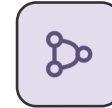
The script invokes the installed assistant with flags that skip the usual permission prompts.



4

The assistant finds the secrets

It reads the filesystem competently and returns exactly what was asked for: credentials and tokens.



5

Data is published outward

Findings are encoded and pushed to a public repository, then used to reach private ones.

The Assistant Helped Them Rob Us

Step by step

- 1 A developer or bioinformatician installs or updates a package in a build, CI job or analysis environment.
- 2 The package's install script executes automatically, which is normal behaviour for the ecosystem.
- 3 The script looks for AI command line tools already on the machine and runs them with permission bypass flags.
- 4 The assistant does what it is good at: it searches the filesystem and reports credentials, tokens and keys.
- 5 Results are encoded and pushed to a public repository under the victim's own account.
- 6 Leaked tokens are then used to expose private repositories, widening the breach well beyond the first machine.

What is at risk

-  Source code and pipelines
-  Cloud and CI credentials
-  Bioinformatics workflows
-  Research data stores
-  Connected SaaS and partners

Business impact

-  Pipeline shutdown and rebuild
-  Credential rotation at scale
-  Disclosure obligations
-  Partner and auditor scrutiny

Estimated financial impact

illustrative range

\$0.25M to \$2M

Investigation and rotation

\$1M to \$5M+

Pipeline rebuild and revalidation

\$1M to \$10M+

IP exposure response

\$5M to \$25M+

Programme delay